EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

POLICY-ISP

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Introduction
2. Scope
3. Roles & Responsibilities
4. Access Control Policies
4.1 User Account Policy
4.2 Remote Access Policy
4.3 Mobile Device Policy
4.4 Separation of Duties Policy
4.5 Information Flow and Control Policy
4.6 Publicly Posted Information Policy
5. Security Awareness and Training Policies
5.1 Security Awareness and Training Policy
5.2 Specialized Role Based Security Training & Awareness Policy
5.3 Insider Threat Policy
6. Audit and Accountability Policy
7. Asset Management, Configuration Management, and Maintenance Policies
7.1 Asset Management Policy
7.2 System Configuration Policy
7.3 Change Management Policy
7.4 Systems Maintenance Policy
7.5 Software Review, Whitelisting, and User-Installed Software Policy
8. Identification and Authentication Policy
9. Password Policy
10. Incident Response Policy
11. Media Protection Policies
11.1 Protecting Media Containing FCI and CUI Policy
11.2 Removable Media Policy
12. Personnel Security Policies
13. Physical Protection Policy
14. IT Risk Management Policy
15. System and Communications Protection Policy
16. System and Informational Integrity Policy
17. Review and Update Policy

POLICY-ISP

1. Introduction

This Information Security Policy outlines the security measures and practices implemented by Exos Aerospace Systems & Technologies, Inc. to protect Controlled Unclassified Information (CUI) within our organization's secure enclave. This policy is designed to comply with DFARS 7012, NIST SP 800-171 requirements, CMMC 2.0 Level 2 guidelines.

2. Scope

This policy applies to Exos Aerospace Systems & Technologies, Inc. users, Third Party Providers (TPPs), contractors, vendors, and agents who are within the secure enclave. This covers all company-owned computers, workstations, mobile devices, or other electronic devices used to connect to M365 GCC High information systems for users within the secure enclave.

3. Roles & Responsibilities

Role	Responsibilities & Authority
Company Admin	Responsible for the company mission, security, and reputation. Appoints and oversee all other roles. Has executive authority over the company's Information Technology. Reviews/approves changes to policies, procedures, configurations, maintain documentation, etc. Is responsible for human resource tasks, such as verifying personnel, processing new users, and separating users. Deals with the budgeting and resource allocation for Compliance requirements.
Security Admin	Deals with high-level IT security issues, supervising users who implement and configure security measures, preparing and overseeing budgets, and evaluating and ordering new security tools and technologies. Coordinates key physical and personnel security functions. Executes IT policies, procedures, and practices.
Compliance Admin	Provides compliance guidance and performs compliance documentation.
User	Day to day user of the IT systems.

4. Access Control Policies

4.1 User Account Policy

- User Accounts will be configured following the documented **SOP-USRMGT**.

Principles of least privilege, account lockout after 10 failed attempts, and session lock after at least 15 minutes will be implemented.

- Users will be assigned unique identifiers which will not be reused until 30 days.
- Passwords will not be reused for at least 10 generations.
- Standard Users will be issued non-privileged accounts.
- Standard Users with a demonstrated need for local administrator access will be issued a separate account exclusively for privileged tasks on their local device.
- Privileged Users will be issued accounts with privileged access, documented, and used for management/maintenance of systems only.
- Privileged Users can use separate profiles to perform management and not use the privileged profile for Standard User functions.
- Temporary passwords will be issued with a requirement for immediate change.
- Users will be presented with privacy and security notice when accessing systems containing CUI with the content
    - This system is for the use of authorized users only. Individuals using this computer system are subject to having all their activities on this system monitored and recorded by system personnel. While monitoring individuals improperly using this system, or during system maintenance, the activities of authorized users may also be monitored. Anyone using this system expressly consents to such monitoring and is advised that if such monitoring reveals possible evidence of criminal activity, system personnel may provide evidence of such monitoring to law enforcement officials. You are entering the CUI zone secured by Atomus. This information system may contain CUI with specific requirements as posted by the DoD.

User accounts will be decommissioned per the **SOP-USRMGT**.

4.2 Remote Access Policy

- The organization does not allow Remote Access capabilities.
- Once required, and authorized by the Company Admin, Remote Access to Company may be performed only through approved and documented methods that employ FIPS 140-2 validated encryption and that are fully tunneled on a private and compliant network.
- Multi-factor authentication must be employed to access the network and company resources.
- Remote access will be monitored regularly by viewing logs for unusual patterns.
- Attempted unauthorized remote access will generate an alert.

4.3 Mobile Device Policy

4.3.1 Personal Mobile Devices | Bring-Your-Own Device (BYOD)

- Personal devices may only access company data using managed, verified Microsoft applications (i.e. Microsoft Teams, Microsoft Outlook, Microsoft Edge Browser, Microsoft Word, etc.).
- Only approved, encrypted methodologies like managed Microsoft applications for mobile devices may access corporate systems or be permitted to contain CUI.
- Managed applications must authenticate to corporate systems using a user account with the appropriate level of access.
- Devices must have up-to-date security protections, including passcode/PIN, device encryption, and automatic lockout.
- The company reserves the right to revoke access or remotely wipe corporate data if a device is lost, stolen, or compromised.
- Users must immediately report lost or compromised devices to the Company or Security Admin.
- Company data and personal data must remain logically separated; users may not transfer, copy, or store company information outside managed apps.
- Upon separation from the company or revocation of access, users must delete all company applications and data from their personal devices.
- No data/information is monitored outside of the Microsoft Applications.

4.4 Separation of Duties Policy

- Important duties and tasks are split between users.
- Roles for Company and Security Admin are split among different people within the Company.

4.5 Information Flow and Control Policy

- Information is classified into Public, Confidential, CUI and Protected Data categories and handled as per the **SOP-INFSENFLOW**.
- Each classification may have specific authorizations for access, handling, distribution, reception, sending, retention, destruction, and marking.

The *Company Admin* reviews and approves all sources and destinations of CUI.

- All regulated information such as CUI, CDI, and CTI must be marked appropriately.

4.6 Publicly Posted Information Policy

- Only information deemed Public per the **Information Sensitivity and Flow SOP** may be posted on public-facing websites.

Only trained Company representatives (*Company Admin*) are permitted to approve any information on public-facing websites.

5. Security Awareness and Training Policies

5.1 Security Awareness and Training Policy

- Security Training will be performed for all users at onboarding, when roles change, and on a regular basis.
- All users shall be provided training on General Cybersecurity Awareness, CUI Handling, and Insider Threat.
- Documentation of trainings, attendees, and dates will be maintained.

5.2 Specialized Role Based Security Training & Awareness Policy

- Individuals with privileged accounts or who are higher targets for malicious actor attacks will receive additional specialized training.
- Every individual as per their role have been trained on appropriate policy and procedures, and how to perform them.

5.3 Insider Threat Policy

- Training focuses on recognizing employee behaviors and characteristics that might be indicators of an insider threat.

Potential insider threats should be reported to management immediately, logged, and investigated.

6. Audit and Accountability Policy

- The audit events that are captured should be identified, and they should have unique traceability capabilities.
- Every audit event from endpoints should have unique username and endpoint associated with it for traceability.
- Every user-related audit event from Cloudflare and Duo should have unique username and endpoint associated with it for traceability. Every admin-related audit for Cloudflare and Duo should include the unique username associated with the action.
- Every audit event from O365, Azure, Intune, and Defender should have unique username associated with it for traceability.
- Every audit event should have a timestamp associated with it, unless it is not relevant.
- Audit information will be collected into one or more central repositories.
- Audit logging processes and configurations should be reviewed at least once annually as part of the **PLAN-RVWITMS**.

- Audit logging processes and configurations should also be reviewed after a confirmed security incident.
- Logs should be monitored at least once quarterly as part of **PLAN-RVWITMS** for suspicious activity. They are also reviewed after a confirmed security incident.
- Alerts generated from events should be investigated as part of the **PLAN-RVWITMS** at least quarterly.
- Logs should be retained for at least 90 days.

In the event of an audit logging process failure, the *Security Admin* should be alerted.

- A SIEM tool should be used to perform review, analyze, and report processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.
- All failures for actions such as not being able to generate defined content, failure of the SIEM to receive, store, process, correlate, or alert, push logs to the SIEM, unable to send logs from devices to the SIEM should be alerted.
- Logs collected will be reviewed for completeness, and updates should be made accordingly, at least once every 6 months as part of the **PLAN-RVWITMS**.

7. Asset Management, Configuration Management, and Maintenance Policies

7.1 Asset Management Policy

- All company-owned and non-company owned assets with access to the enclave will be identified and maintained in the **Asset Inventory**.
- The inventory will be maintained throughout the system development life cycle.
- An updated **network diagram** showing assets' relation to each other will be maintained.

Any asset that goes out of control due to maintenance purposes should be properly sanitized of any CUI or destroyed following **SOP-DVCSAN** before it leaves the physical control of the designated owner.

- Decommissioned assets must be properly sanitized of any CUI or destroyed following **SOP-DVC-SAN**.

7.2 System Configuration Policy

- Baseline configurations will be documented.
- Configurations will follow the principles of the least functionality.
- Baseline configurations should represent the most secure state consistent with operational requirements and constraints.
- Baseline Configurations will be maintained following the System Development Life Cycle process of reviewing, testing the changes, rolling out to a smaller group, and then deploying to everyone applicable, and completing the Change Management item.

7.3 Change Management Policy

- Changes to the IT systems will follow **SOP-CHNGMGT**.
- The process will detail who can make changes, approval requirements, documentation, testing, validation, review, and approval.
- All changes will have the physical and logical access restrictions mentioned in the description if they are applicable.

Only authorized personnel as per the **RACI Matrix** may physically and logically access systems for maintenance, upgrades, or modifications to system configurations, and only implemented after due approval.

- Logical access restrictions are enforced to be maintained only by the authorized personnel as per the **RACI Matrix**.
- Physical access and presence will be required when working on system changes with external vendors.

Systems subject to change control must be at least physically or logically access controlled by the *Security Admin* or the *Company Admin* to make the changes.

7.4 Systems Maintenance Policy

- Systems will be maintained according to manufacturers' recommendations, updates, and security advisories.
- Tools used for maintenance will be analyzed at least yearly for security concerns.
- Any non-local maintenance to systems will require multi-factor authentication.
- Any non-local maintenance to systems will be terminated once complete.
- Any non-local maintenance to systems will require visual supervision.
- Any maintenance session with personnel without required access will be supervised at all times during the maintenance sessions.
- All media containing diagnostic and test programs will be checked for malicious code before being used in the organizational systems.
- Any physical maintenance will require the physical presence of an authorized user.
- Any physical maintenance that cannot have physical presence of an authorized user, the endpoint would have to be sanitized as per **SOP-DVCSAN**.

7.5 Software Review, Whitelisting, and User-Installed Software Policy

- All software installed on corporate systems will be reviewed and monitored.
- All software will have a digital certificate for an official publisher (i.e. signed applications) for all device-level software, unless it is a user-level software, and not allow any malicious software or unsigned applications.

- Approved software will be documented on the **Software Inventory**.

8. Identification and Authentication Policy

- All devices, processes, and users must be identified by unique names and utilize approved, secure methods to authenticate with Authorized Systems.
- Multi-factor authentication is required for local and network access for both privileged and non-privileged accounts.
- All authentication policies will use Role-based Access Control (RBAC) for all identification purposes,and follow least privileged role management.
- Accounts will be locked after 10 failed password attempts.
- Atomus devices are authorized to access M365 administrative consoles for tenant configuration and administration, using unlicensed privileged accounts with no access to O365 applications. These devices are not company-owned, so they are not tracked in the Asset Inventory and are not subject to device level conditional access.

9. Password Policy

- Users and devices will authenticate to corporate systems by means of a secure password.
- All digitally stored and transmitted passwords are encrypted.
- The password complexity will be at least 8 characters in length, are alphanumeric, with no common phrases or long sequences of repeating patterns, a minimum age of 1 day, and a maximum age of unlimited.
- Password cannot be reused for 10 generations.
- Everywhere a password is used, it should be obscured.

10. Incident Response Policy

- Security Incidents shall be responded to as soon as they are uncovered by the Incident Response Team which includes the Security Admin.
- The **PLAN-IR** should be tested and reviewed at least yearly.
- All incidents should be reported internally to the appropriate stakeholders including Company Admin, Security Admin, and the affected user.
- Report incidents involving DoD contracts to DoD Incident Reporting authority, DIBNET.
- Conduct annual tests using CISA-provided **Incident Response Table-Top Exercise**.

11. Media Protection Policies

11.1 Protecting Media Containing FCI and CUI Policy

- All media containing FCI or CUI will be handled and secured by the **SOP-INFSENFLOW**.
- Media containing FCI will be marked "Controlled" and media containing CUI will be marked as such and with distribution limitations.
- When transporting media containing CUI, a chain of custody must be maintained and authorized by the Company Admin.
- No CUI is allowed for printing at all.
- Users with access to authorized printers connected via serial connection may print only non-CUI media. Network-connected or wireless printing is not permitted.

11.2 Removable Media Policy

- The organization will not allow any use of portable storage devices on external systems unless explicitly whitelisted. Portable storage devices will not be used to store CUI.
- The organization will not allow any use of removable media on authorized systems unless explicitly whitelisted. Removable media will not be used to store CUI.
- The use of removable media with no identifiable owner is strictly prohibited.
- All removable media will be tracked along with an identifiable owner.
- If unable to identify the owner, portable media must be destroyed.
- Label media containing CUI as "CUI" with appropriate distribution limitations
- All removable media should be put through a malicious code check before being used in any organizational system.
- The organization will use approved methodologies to sanitize or destroy system media before disposal and released for reuse.
- Store media containing CUI in a locked and secure location within the employee's designated remote work area.

12. Personnel Security Policies

The *Company Admin*, in coordination with the *Security Admin*, will create and maintain Onboarding, Transfer, and Offboarding procedures.

- All individuals will be screened and approved prior to authorizing access to the systems.
- Third Party Providers (TPPs) who require maintenance/support access to corporate systems will be appropriately vetted and perform maintenance under authorized supervision.

13. Physical Protection Policy

- Digital infrastructure must be secured by either locked doors or cabinets.
- The organization does not allow any storage of any physical CUI or paper CUI.
- All physical spaces designated for CUI should be only accessible by authorized individuals.

If physical CUI is authorized, it must be stored in a locked and secure location when not in use, as approved by the *Company Admin*.

14. IT Risk Management Policy

- Risks must be assessed regularly per the **SOP-RSKMRSPN**.
- The Company will perform a Security Assessment at least yearly on all corporate systems.
- The Company formally engages in Risk Assessments and security planning during quarterly Risk Assessment Meetings.

15. System and Communications Protection Policy

- All devices with access to CUI must be encrypted using FIPS 140-2 validated cryptography.
- The Company will design and engineer system security with guidance from NIST SP 800-160.
- A vendor-supported firewall should be maintained at the external system boundary in case of presence of local IT assets.
- All communications will be monitored, controlled and protected at the external and internal system boundary.
- All systems should use TLS encryption for all transmissions and cloud-based communications.
- No publicly accessible systems for the organization is allowed inside the corporate network.
- All shared system resources are protected by Role-based access control (Group-based) on all applicable systems.
- All network communication traffic is denied by default with exceptions.
- All cryptographic keys are established by the system which employs the cryptography.
- All cryptographic keys will be managed by the system which employs the cryptography.
- Locked cabinets, physical control of the device at all times are alternative physical safeguards intended to prevent unauthorized disclosure of CUI.
- Remote activation of collaborative computing devices should not be allowed, and all devices should show an indication of a collaborative computing device being in use, like MacOS shows orange dot (for Microphone), and green dot (for Camera) usage on the top right of the screen.
- No mobile code is authorized.
- No split-tunneling is allowed.
- If VoIP Systems are employed, they will be logically or physically separated from all other networks.
- All communication sessions authenticity is protected.
- All inactive network connections associated with communications sessions are terminated within a maximum of 1 hour of inactivity.

16. System and Informational Integrity Policy

- Vulnerability scans shall be conducted to identify flaws and reported and corrected per the **SOP-VLNSCNREM**
- All user reported system flaws are reported to the Security Admin via email.
- Manufacturer approved security patches will be applied as soon as possible.
- Protection against malware and malicious actors will be present on Authorized Devices.

All security alerts and advisories like CISA, Microsoft will be subscribed to by the *Security Admin* and *Company Admin*.

17. Review and Update Policy

This policy will be reviewed and updated at least annually or when significant changes occur to the information system. All updates will be communicated to relevant stakeholders.

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "POLICY-ISP".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of POLICY-ISP (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE



DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026